

Care Access Navigator - Day 3

Establish Risk & Compliance Foundation

HealthLine Regional Medical Center

IAM + GRC Healthcare Cybersecurity Capstone | Frameworks, Risks & Control Objectives

Organization	HealthLine Regional Medical Center (HRMC)	Day 3 Focus	Frameworks → Risks → Controls
Communication	Technical + Non-Technical Stakeholders	Project Outcome	Clear rationale for risks and controls
Project Phase	Week 1: Planning	Data Rule	Synthetic Data Only

1. Day 3 Overview

Purpose: Day 3 connects the hospital environment from Days 1-2 to security expectations, risks, and control objectives. No controls are implemented yet; this is the planning and analysis step before configuration.

Simple flow: What rules apply? → What could go wrong? → How serious is it? → What should a good control achieve? → Later, how do we implement and prove it?

Project explanation: “After defining the hospital environment and access needs, I reviewed the relevant frameworks, identified realistic IAM/GRC risks, and defined control objectives that can later be implemented and tested.”

2. HIPAA Security Rule Concepts

Purpose: Review the healthcare security concepts that are most relevant to the project, including workforce security, information access management, authentication, audit logging, incident handling, and protection of ePHI.

Project explanation: “Because HRMC is a healthcare environment, I reviewed the HIPAA security concepts that affect identity and access. For example, employee access should change when job responsibilities change, terminated users should lose access, and system activity should be traceable.”

Analyst takeaway: Compliance requirements help explain why IAM controls such as JML workflows, authentication, access restrictions, and logging are necessary.

3. NIST CSF 2.0 Concepts

Purpose: Use NIST CSF to organize the cybersecurity work into Govern, Identify, Protect, Detect, Respond, and Recover.

NIST Function	Plain-Language Meaning
Govern	Set direction, responsibilities, policy, and risk approach.
Identify	Know the users, systems, data, assets, and risks.
Protect	Use IAM, authentication, RBAC, least privilege, and data safeguards.
Detect	Use logs and monitoring to notice suspicious activity.
Respond	Investigate, escalate, contain, and document incidents.
Recover	Restore normal operations and learn from the event.

Project explanation: “HIPAA provides healthcare-specific security expectations, while NIST provides a practical structure for organizing the cybersecurity work.”

4. Initial IAM/GRC Risk Register

Purpose: Convert the Day 1-2 users, applications, and requirements into a list of realistic IAM/GRC risks. Simple Low/Medium/High likelihood and impact ratings are used to support prioritization.

Example Risk	Plain-Language Example
Mover risk	A nurse moves to Billing but keeps unnecessary nursing access.
Leaver risk	An employee leaves HRMC but the account remains active.
Vendor risk	A vendor account remains enabled after the approved end date.
Segregation risk	Billing or HR can see patient information they do not need.
Monitoring risk	Unusually high patient-record access is not detected.
Privileged-access risk	A role grant or revoke is performed without oversight.

Project explanation: “The risk register turns broad concerns such as inappropriate access into specific, trackable risks that can be prioritized and addressed.”

Analyst takeaway: Risk should be identified and prioritized before deciding which control or technology should address it.

5. Preliminary Control Objectives

Purpose: Define the security outcome a future control should achieve for each important risk before deciding the exact technical implementation.

Step	Example
Risk	Terminated user keeps access.
Control objective	Remove access within a defined timeframe after termination.
Later IAM implementation	Disable the account / remove roles through the JML process.
Future evidence	Termination request, approval, account status, and deprovisioning log.
Key idea: Risk tells me what could go wrong. A control objective tells me what should happen to reduce that risk.	

Project explanation: “Each control objective is mapped back to a named risk and relevant framework concept. This creates a clear reason for each RBAC, logging, monitoring, or lifecycle control implemented later.”

6. Why Framework Mapping Matters

Purpose: Create traceability so each control can be linked to the risk it addresses and the framework expectation that supports it.

Traceability chain: Business scenario → Risk → Control objective → Framework → Implementation → Evidence → Remediation if needed

Project explanation: “If someone asks why a control exists, it can be traced back to a business risk and a security requirement rather than simply to a tool capability.”

7. Key Terms & Practical Reference

Term	Plain-Language Meaning
Risk	Something that could happen and negatively affect the organization.
Risk register	A tracked list of risks with context and rough priority.
Control	A safeguard used to prevent, detect, or reduce risk.
Control objective	The outcome a control should achieve before deciding exactly how to build it.
Evidence	Proof that a control exists or operated, such as a log, approval, screenshot, or review record.
Remediation	The action taken to correct a control gap or security problem.
RBAC	Role-Based Access Control: access is assigned based on job role.
JML	Joiner-Mover-Leaver: managing access when a person joins, changes roles, or leaves.

Practical use: These terms support consistent communication across IAM, GRC, security, and business stakeholders throughout the project.